Course: Cryptography and Network Security
Code: CSN15403
Branch: B.Tech -5th Semester

Lecture – 17 : Entity Authentication

Faculty & Coordinator : Dr. J Sathish Kumar (JSK)

Department of Computer Science and Engineering

Motilal Nehru National Institute of Technology Allahabad,
Prayagraj-211004

Entity Authentication

- Entity authentication is a technique designed to let one party prove the identity of another party.
- An entity can be a person, a process, a client, or a server.
- The entity whose identity needs to be proved is called the **claimant**; the party that tries to prove the identity of the claimant is called the **verifier.**
- When Bob tries to prove the identity of Alice, Alice is the claimant, and Bob is the verifier.

Data-Origin Versus Entity Authentication

- Message authentication (or data-origin authentication) might not happen in real time; entity authentication does.
  - In the former, Alice sends a message to Bob. When Bob authenticates the message, Alice may or may not be present in the communication process.
  - On the other hand, when Alice requests entity authentication, there is no real message communication involved until Alice is authenticated by Bob. Alice needs to be online and to take part in the process. Only after she is authenticated can messages be communicated between Alice and Bob.
  - Data-origin authentication is required when an email is sent from Alice to Bob.
  - Entity authentication is required when Alice gets cash from an automatic teller machine

Data-Origin Versus Entity Authentication

- Second, message authentication simply authenticates one message; the process needs to be repeated for each new message.
- Entity authentication authenticates the claimant for the entire duration of a session.

Verification Categories

- In entity authentication, the claimant must identify herself to the verifier. This can be done with one of three kinds of witnesses: something known, something possessed, or something inherent
- **Something known**.
  - This is a secret known only by the claimant that can be checked by the verifier.
  - Examples are a password, a PIN, a secret key, and a private key
- **Something possessed**.
  - This is something that can prove the claimant's identity.
  - Examples are a passport, a driver's license, an identification card, a credit card, and a smart card
- **Something inherent**.
  - This is an inherent characteristic of the claimant.
  - Examples are conventional signatures, fingerprints, voice, facial characteristics, retinal pattern, and handwriting.

PASSWORDS

- The simplest and oldest method of entity authentication is the password-based authentication, where the password is something that the claimant knows.
- A password is used when a user needs to access a system to use the system's resources (login).
- Each user has a user identification that is public, and a password that is private.
- We can divide these authentication schemes into two groups:
  - The fixed password and
  - The one-time password

Fixed Password

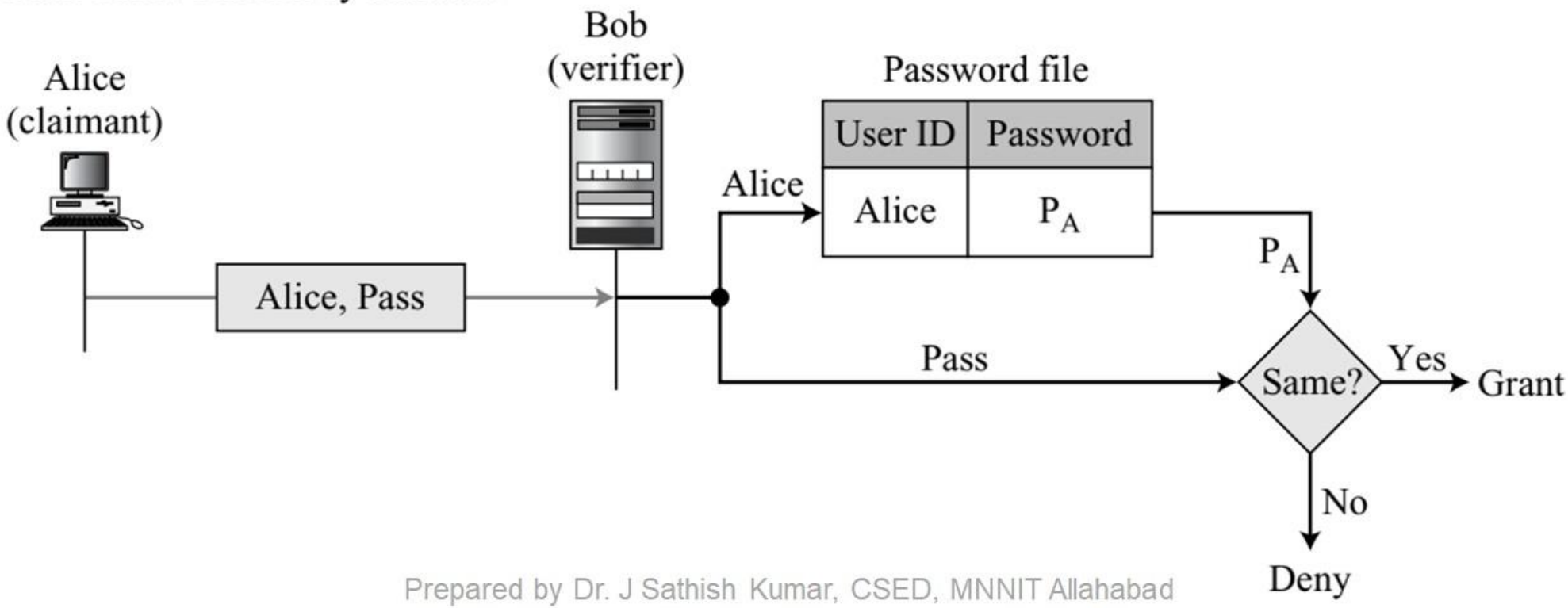
- A fixed password is a password that is used over and over again for every access.
- Several schemes have been built, one upon the other.
- First Approach : User ID and password file
- Second Approach : Hashing the password
- Third Approach : Salting the password

Fixed Password

User ID and password file

P_A: Alice's stored password

Pass: Password sent by claimant



Fixed Password

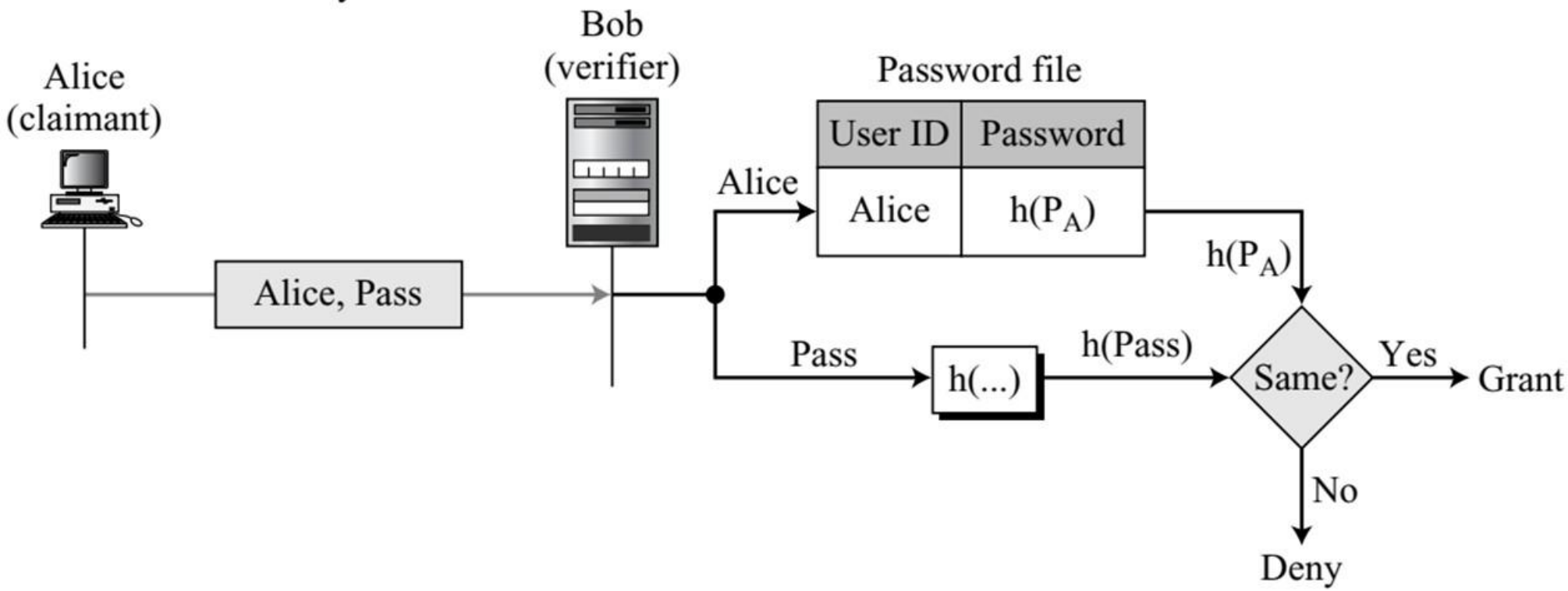
- Attacks on the First Approach
  - Eavesdropping.
    - Eve can watch Alice when she types her password.
    - Most systems, as a security measure, do not show the characters a user types.
  - Stealing a password.
    - The second type of attack occurs when Eve tries to physically steal Alice's password.
    - This can be prevented if Alice does not write down the password and instead she just commits it to memory.
  - Accessing a password file.
    - Eve can hack into the system and get access to the ID/password file.
    - To prevent this type of attack, the file can be read/write protected.
  - Guessing.
    - Using a guessing attack, Eve can log into the system and try to guess Alice's password by trying different combinations of characters.
    - It is also vulnerable if Alice has chosen something trivial, such as her birthday, her child's name, or the name of her favorite actor.
    - To prevent this type of attack , a long random password is recommended, something that is not very obvious.

Fixed Password

Hashing the password

P_A: Alice's stored password

Pass: Password sent by claimant



Fixed Password

- **Dictionary Attack**
  - The hash function prevents Eve from gaining access to the system even though she has the password file. However, there is still the possibility of dictionary attack.
  - In this attack, Eve is interested in finding one password, regardless of the user ID.
  - For example, if the password is 6 digits, Eve can create a list of 6-digit numbers (000000 to 999999), and then apply the hash function to every number; the result is a list of one million hashes.
  - She can then get the password file and search the second-column entries to find a match. This could be programmed and run offline on Eve's private computer.
  - After a match is found, Eve can go online and use the password to access the system.

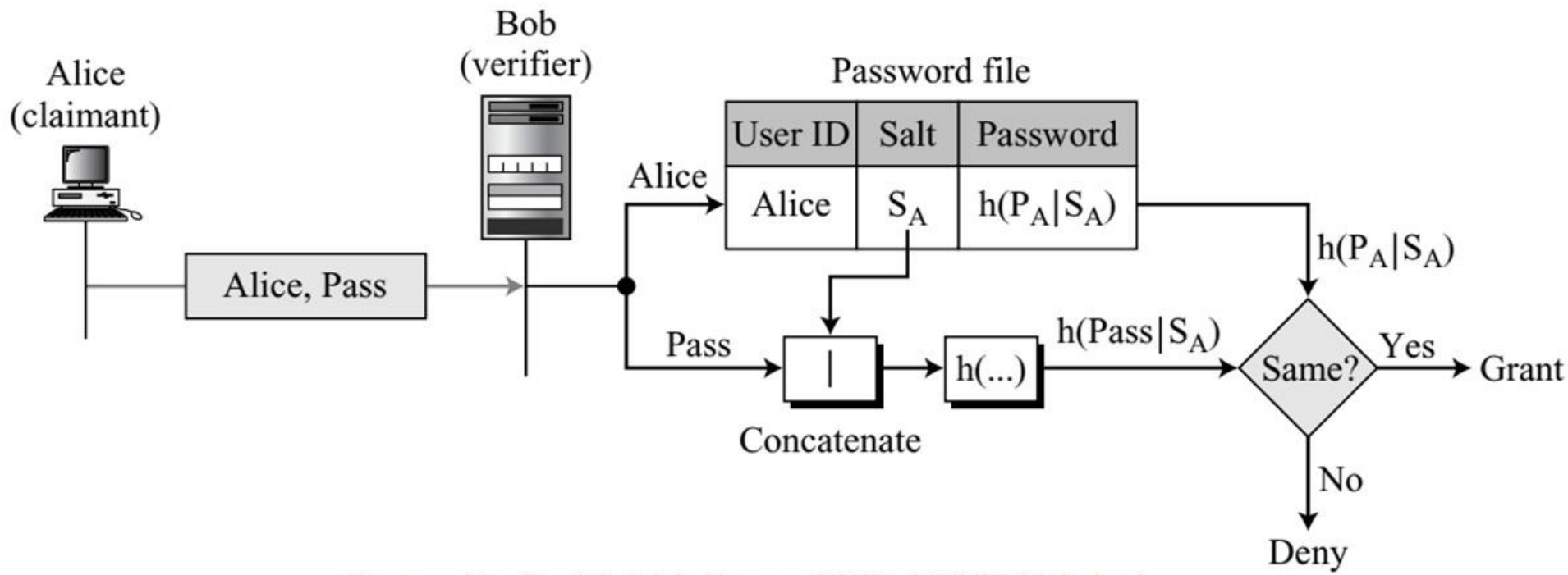
Fixed Password

Salting the password

P_A: Alice's password

S_A: Alice's salt

Pass: Password sent by claimant



Fixed Password

- Salting the password
  - When the password string is created, a random string, called the salt, is concatenated to the password.
  - The salted password is then hashed.
  - The ID, the salt, and the hash are then stored in the file.
  - Now, when a user asks for access, the system extracts the salt, concatenates it with the received password, makes a hash out of the result, and compares it with the hash stored in the file.
  - Salting makes the dictionary attack more difficult.
  - If the original password is 6 digits and the salt is 4 digits, then hashing is done over a 10-digit value. This means that Eve now needs to make a list of 10 million items and create a hash for each of them.
  - The list of hashes has 10 million entries, and the comparison takes much longer.
  - Salting is very effective if the salt is a very long random number.

Fixed Password

- Fourth Approach
  - Two identification techniques are combined.
  - A good example of this type of authentication is the use of an ATM card with a PIN (personal identification number).
  - The card belongs to the category “something possessed ” and the PIN belongs to the category “something known”.
  - The PIN is a password that enhances the security of the card.
  - If the card is stolen, it cannot be used unless the PIN is known.
  - The PIN number, however, is traditionally very short so it is easily remembered by the owner.
  - This makes it vulnerable to the guessing type of attack

One-Time Password

- A one-time password is a password that is used only once.
- This kind of password makes eavesdropping and salting useless.
- Three approaches are discussed
- First Approach
  - In the first approach, the user and the system agree upon a list of passwords.
  - Each password on the list can be used only once.
  - There are some drawbacks to this approach.
  - First, the system and the user must keep a long list of passwords.
  - Second, if the user does not use the passwords in sequence, the system needs to perform a long search to find the match.
  - This scheme makes eavesdropping and reuse of the password useless.
  - The password is valid only once and cannot be used again.

One-Time Password

- Second Approach
- In the second approach, the user and the system agree to sequentially update the password.
- The user and the system agree on an original password, P1, which is valid only for the first access.
- During the first access, the user generates a new password, P2, and encrypts this password with P1 as the key.
- P2 is the password for the second access.
- During the second access, the user generates a new password, P3, and encrypts it with P2; P3 is used for the third access.
- In other words, Pi is used to create Pi+1.
- Of course, if Eve can guess the first password (P1), she can find all of the subsequent ones.

One-Time Password

- Third Approach
- In the third approach, the user and the system create a sequentially updated password using a hash function.
- In this approach, elegantly devised by Leslie Lamport, the user and the system agree upon an original password, P0, and a counter, n.
- The system calculates $h^n(P0)$, where h^n means applying a hash function n times. In other words,

$$h^n(x) = h(h^{n-1}(x)) \quad h^{n-1}(x) = h(h^{n-2}(x)) \quad \ldots \quad h^2(x) = h(h(x)) \quad h^1(x) = h(x)$$

The system stores the identity of Alice, the value of n, and the value of $h^n(P0)$

One-Time Password

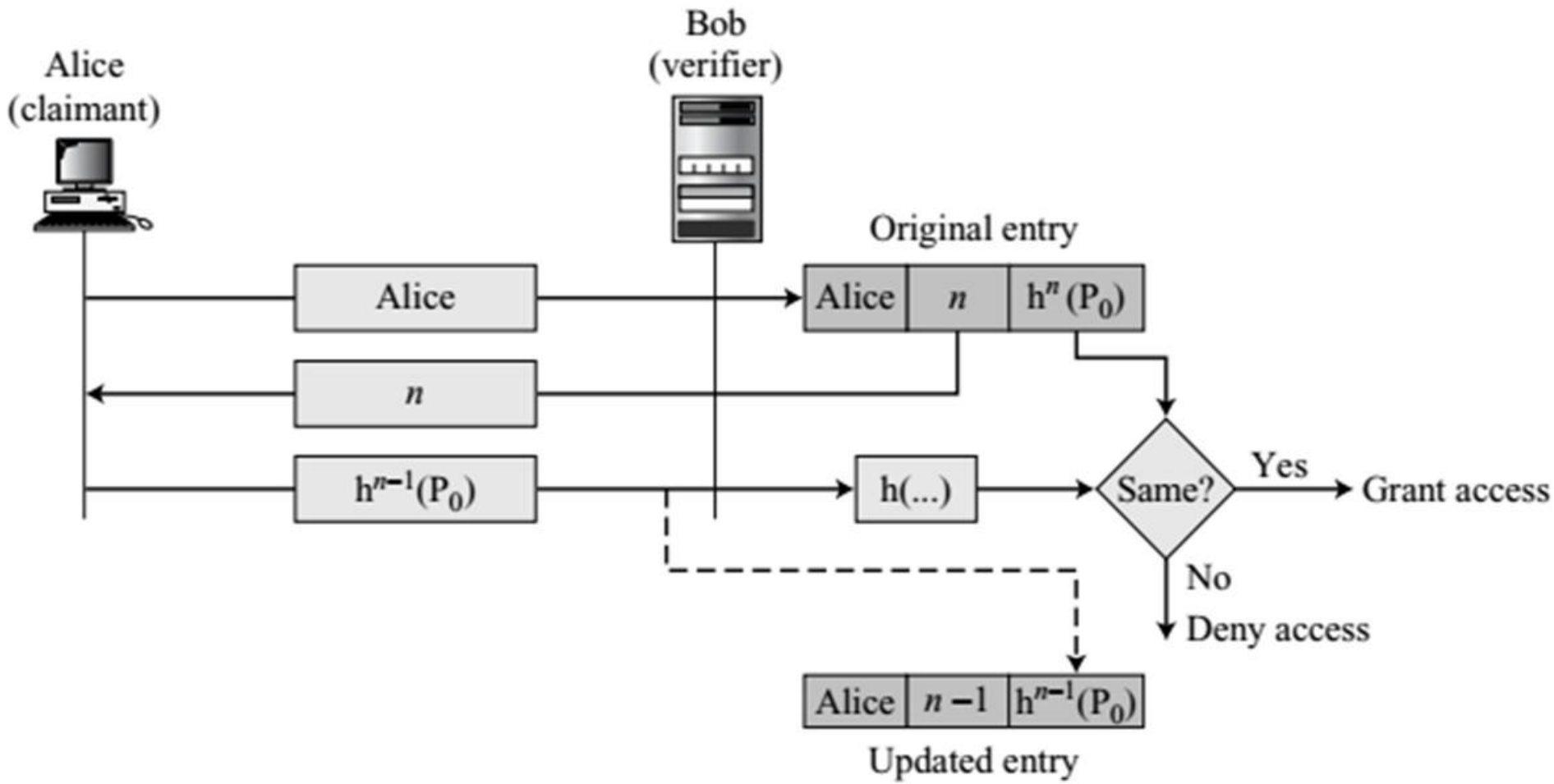
- The system stores the identity of Alice, the value of n, and the value of $h^n(P0)$.
- When the system receives the response of the user in the third message, it applies the hash function to the value received to see if it matches the value stored in the entry.
- If there is a match, access is granted; otherwise, it is denied.
- The system then decrements the value of n in the entry and replaces the old value of the password $h^n(P0)$ with the new value $h^{n-1}(P0)$.

One-Time Password

- When the user tries to access the system for the second time, the value of the counter it receives is n − 1.
- The third message from the user is now $h^{n-2}(P0)$.
- When the system receives this message, it applies the hash function to get $h^{n-1}(P0)$, which can be compared with the updated entry.
- The value of n in the entry is decremented each time there is an access.
- When the value becomes 0, the user can no longer access the system; everything must be set up again.
- For this reason, the value of n is normally chosen as a large number such as 1000.

One-Time Password

Lamport one-time password



ZERO-KNOWLEDGE

- In password authentication, the claimant needs to send her secret (the password) to the verifier; this is subject to eavesdropping by Eve.
- In addition, a dishonest verifier could reveal the password to others or use it to impersonate the claimant.
- In zero-knowledge authentication, the claimant does not reveal anything that might endanger the confidentiality of the secret.
- The claimant proves to the verifier that she knows a secret, without revealing it.

ZERO-KNOWLEDGE

- The interactions are so designed that they cannot lead to revealing or guessing the secret.
- After exchanging messages, the verifier only knows that the claimant does or does not have the secret, nothing more.
- The result is a yes/no situation, just a single bit of information.
- In zero-knowledge authentication, the claimant proves that she knows a secret without revealing it.

Fiat-Shamir Protocol

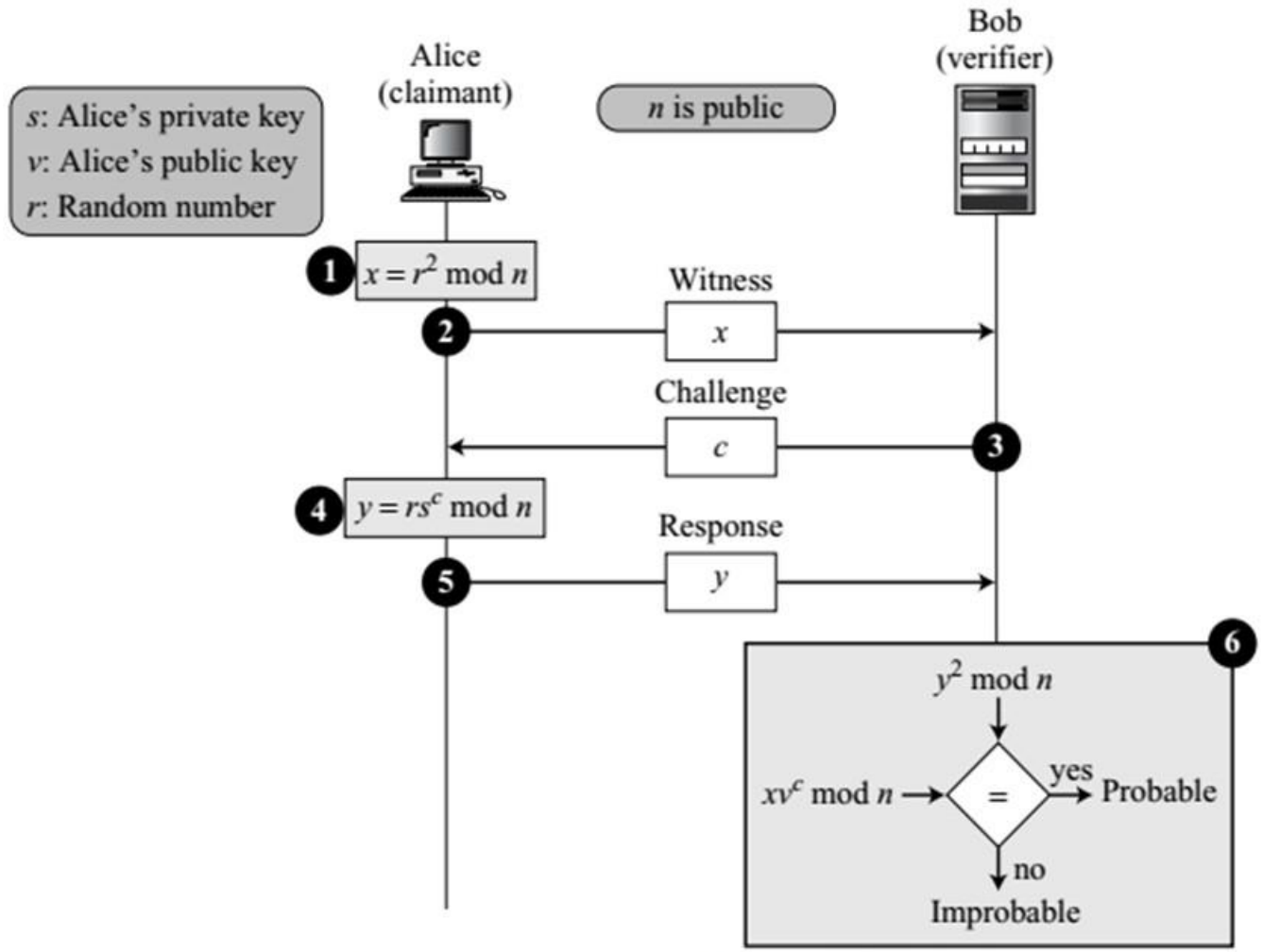
- In the Fiat-Shamir protocol, a trusted third party chooses two large prime numbers p and q to calculate the value of $n = p \times q$.
- The value of n is announced to the public; the values of p and q are kept secret.
- Alice, the claimant, chooses a secret number s between 1 and n − 1 (exclusive).
- She calculates $v = s^2 \bmod n$.
- She keeps s as her private key and registers v as her public key with the third party.
- Verification of Alice by Bob can be done in four steps

Fiat-Shamir Protocol

1. Alice, the claimant, chooses a random number r between 0 and n − 1 (r is called the commitment). She then calculates the value of $x = r^2 \bmod n$; x is called the witness.
2. Alice sends x to Bob as the witness.
3. Bob, the verifier, sends the challenge c to Alice. The value of c is either 0 or 1.
4. Alice calculates the response $y = rs^c$. Note that r is the random number selected by Alice in the first step, s is her private key, and c is the challenge (0 or 1).
5. Alice sends the response to Bob to show that she knows the value of her private key, s. She claims to be Alice.
6. Bob calculates y^2 and xv^c. If these two values are congruent, then Alice either knows the value of s (she is honest) or she has calculated the value of y in some other ways (dishonest) because we can easily prove that y^2 is the same as xv^c in modulo n arithmetic as shown below:

$$y^2 = (rs^c)^2 = r^2 s^{2c} = r^2 (s^2)^c = xv^c$$

Fiat-Shamir Protocol



Fiat-Shamir Protocol

- Let us elaborate on this interesting protocol. Alice can be honest (knows the value of s) or dishonest (does not know the value of s).
- If she is honest, she passes each round.
- If she is not, she still can pass a round by predicting the value of challenge correctly.
- Two situations can happen:
- Alice guesses that the value of c (the challenge) will be 1 (a prediction).
- She calculates $x = r^2/v$ and sends x as the witness.

a) If her guess is correct (c turned out to be 1), she sends y = r as the response. We can see that she passes the test ($y^2 = xv^c$).

b) If her guess is wrong (c turned out to be 0), she cannot find a value of y that passes the test. She probably quits or sends a value that does not pass the test and Bob will abort the process.

Fiat-Shamir Protocol

- Second Situation : Alice guesses that the value of c (challenge) will be 0. She calculates $x = r^2$ and sends x as the witness.
  a) If her guess is correct (c turned out to be 0), she sends y = r as the response. We can see that she passes the test ($y^2 = xv^c$).
  b) If her guess is wrong (c turned out to be 1), she cannot find a value of y that passes the rest. She probably quits or sends a value that does not pass the test and Bob will abort the process.
- We can see that a dishonest claimant has a 50 percent chance of fooling the verifier and passing the test (by predicting the value of the challenge).
- In other words, Bob assigns a probability of 1/2 to each round of the test.
- If the process is repeated 20 times, the probability decreases to $(1/2)^{20}$ or 9.54×10^{-7}.
- In other words, it is highly improbable that Alice can guess correctly 20 times.

Feige-Fiat-Shamir Protocol

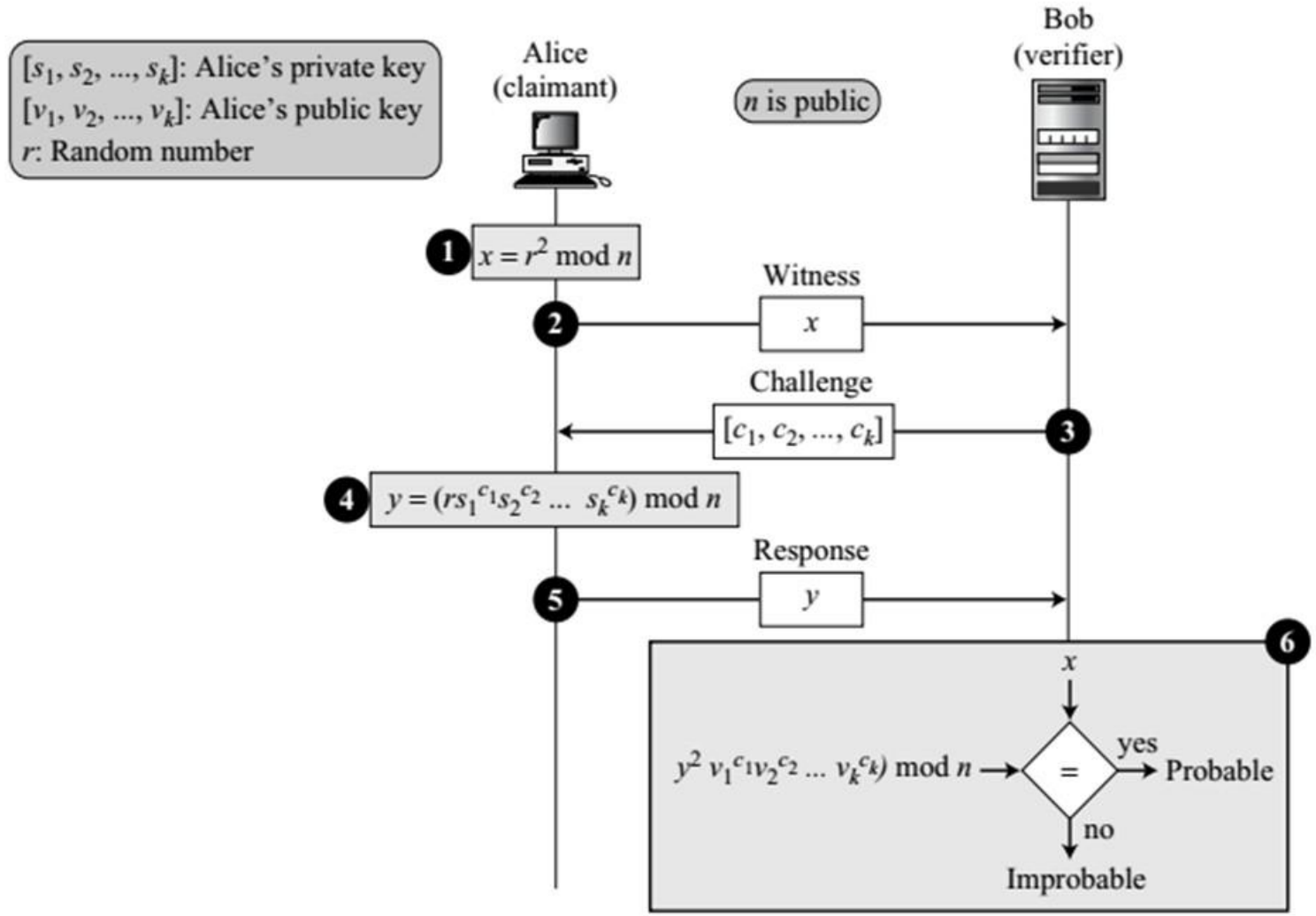
- The Feige-Fiat-Shamir protocol is similar to the first approach except that it uses a vector of private keys [s1, s2, …, sk], a vector of public keys [v1, v2, …, vk], and a vector of challenges (c1, c2, …, ck).
- The private keys are chosen randomly, but they must be relatively prime to n.
- The public keys are chosen such that $v_i = (s_i^2)^{-1} \bmod n$.

$$y^2 v_1^{c_1} v_2^{c_2} \dots v_k^{c_k} = r^2 (s_1^{c_1})^2 (s_2^{c_2})^2 \dots (s_k^{c_k})^2 \, v_1^{c_1} v_2^{c_2} \dots v_k^{c_k}$$

$$= x \, (s_1^2)^{c_1} (v_1^{c_1}) \, (s_2^2)^{c_2} (v_2^{c_2}) \dots (s_2^2)^{c_2} (v_2^{c_k})$$

$$= x \, (s_1^2 v_1)^{c_1} \, (s_2^2 v_2)^{c_2} \dots (s_k^2 v_k)^{c_k} = x \, (1)^{c_1} \, (1)^{c_2} \dots (1)^{c_k} = x$$

Feige-Fiat-Shamir Protocol

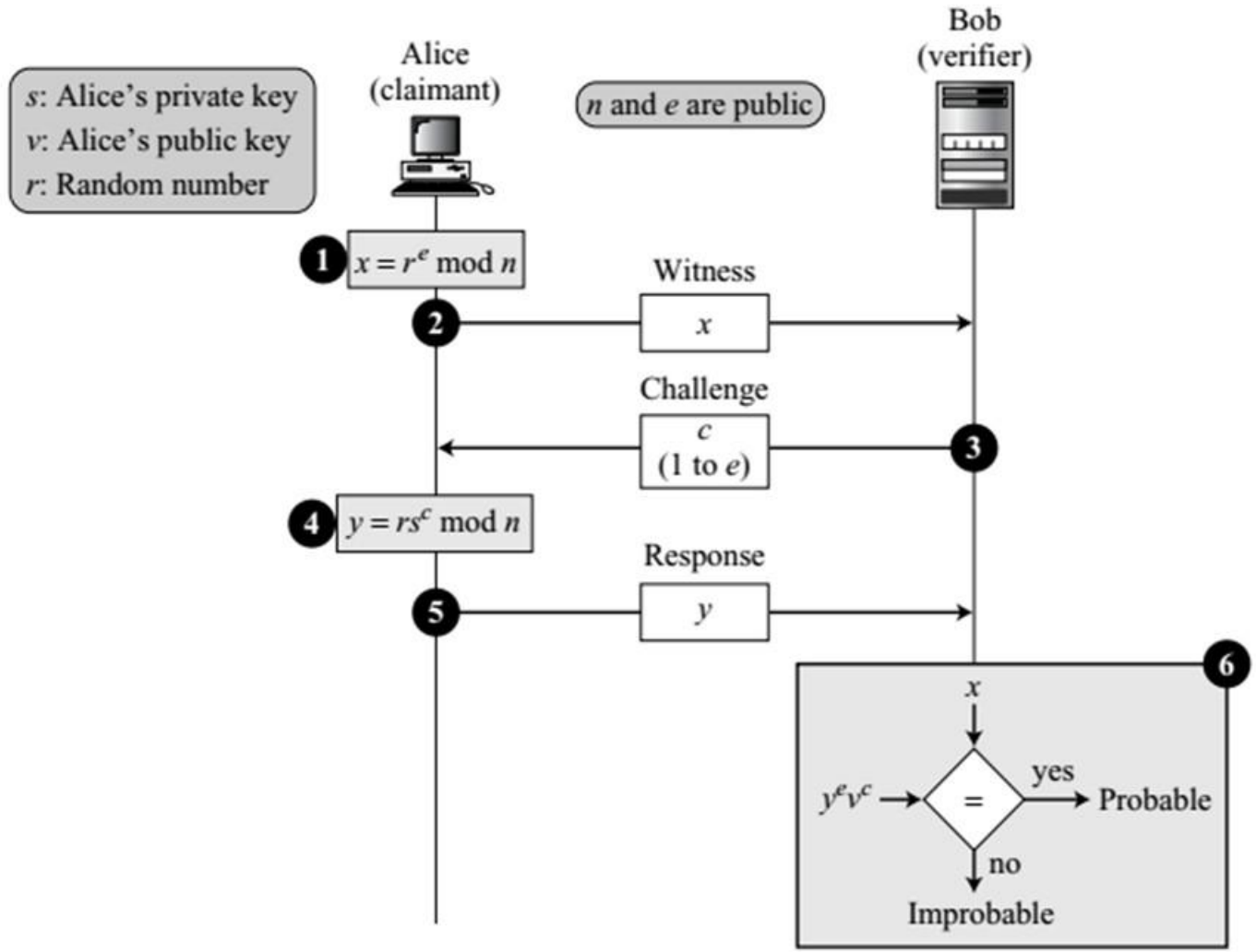


Guillou-Quisquater Protocol

- The Guillou-Quisquater protocol is an extension of the Fiat-Shamir protocol in which fewer number of rounds can be used to prove the identity of the claimant.
- A trusted third party chooses two large prime numbers p and q to calculate the value of $n = p \times q$. The trusted party also chooses an exponent, e, which is coprime with ϕ, where $\phi = (p - 1)(q - 1)$.
- The values of n and e are announced to the public; the values of p and q are kept secret.
- The trusted party chooses two numbers for each entity, v which is public and s which is secret. However, in this case, the relationship between v and s is different: $s^e \times v = 1 \bmod n$

$$y^e \times v^c = (r \times s^c)^e \times v^c = r^e \times s^{ce} \times v^c = r^e \times (s^e \times v)^c = x \times 1^c = x$$

Guillou-Quisquater Protocol

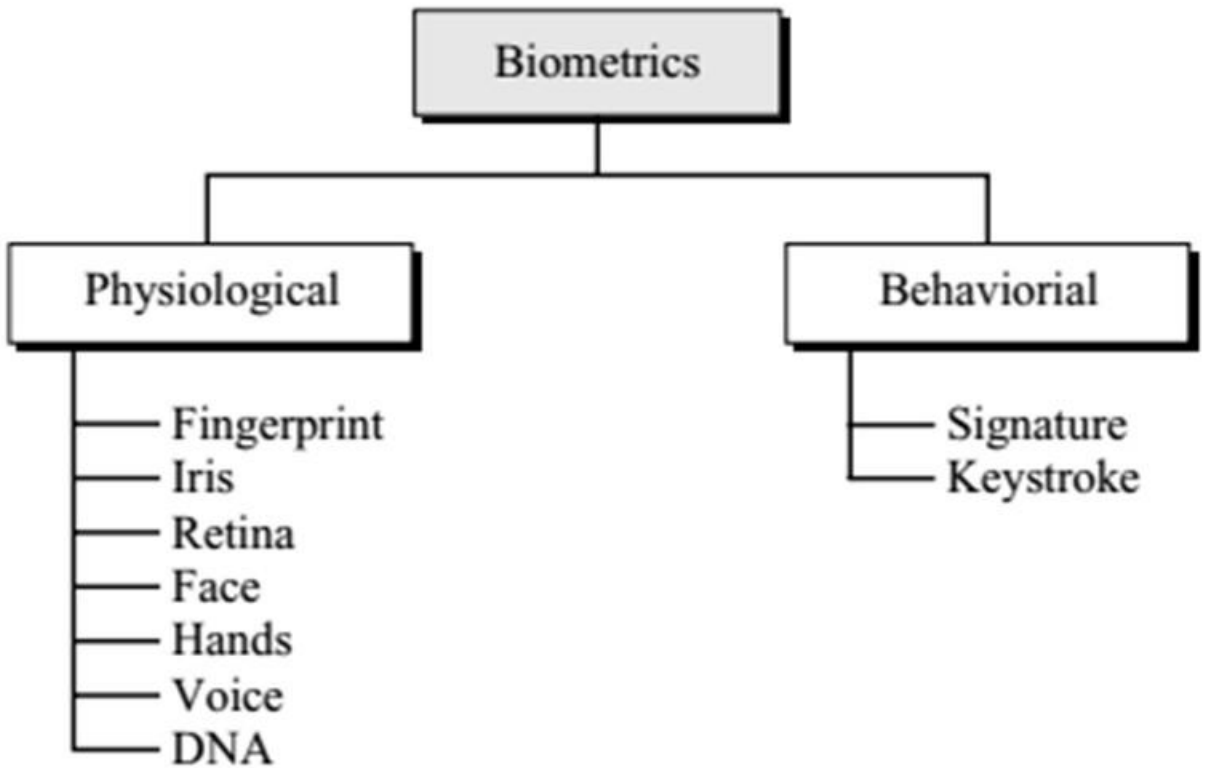


BIOMETRICS

- Biometrics is the measurement of physiological or behavioral features that identify a person (authentication by something inherent).
- Biometrics measures features that cannot be guessed, stolen, or shared.
- Enrollment
  - Before using any biometric techniques for authentication, the corresponding feature ofeach person in the community should be available in the database. This is referred to as enrollment.
- Authentication
  - Authentication is done by verification or identification
- Verification
  - In verification, a person's feature is matched against a single record in the database (one-to-one matching) to find if she is who she is claiming to be. This is useful, for example, when a bank needs to verify a customer's signature on a check.
- Identification
  - In identification, a person's feature is matched against all records in the database (oneto-many matching) to find if she has a record in the database. This is useful, for example, when a company needs to allow access to the building only to employees.

BIOMETRICS

- Techniques



BIOMETRICS

- Accuracy
- Accuracy of biometric techniques is measured using two parameters: false rejection rate (FRR) and false acceptance rate (FAR).
- False Rejection Rate (FRR)
  - This parameter measures how often a person, who should be recognized, is not recognized by the system. FRR is measured as the ratio of false rejection to the total number of attempts (in percentage)
- False Acceptance Rate (FAR)
  - This parameter measures how often a person, who should not be recognized, is recognized by the system. FAR is measured as the ratio of false acceptance to the total number of attempts (in percentage).